Information Security, Data Protection & IT Acceptable Use Policy

Classification: Internal Corporate Directive · Version: 4.0 · Department: Infosec Legal

1. Data Classification Scheme & Encryption Standards

All digital and physical information assets owned or processed by Acme Global Enterprise must be categorized into one of four classification tiers:

1.1 Tier 1 - Public: Marketing collaterals, press releases, public open-source repositories. No confidentiality controls required.

1.2 Tier 2 - Internal: Internal memos, company wiki pages, organizational rosters. Access limited to authenticated Acme staff.

1.3 Tier 3 - Confidential: Customer Personally Identifiable Information (PII), employee payroll files, proprietary source code, and commercial contract drafts. Mandatory AES-256 encryption at rest and TLS 1.3 encryption in transit.

1.4 Tier 4 - Highly Restricted: Executive M&A strategies, master database cryptographic keys, banking credentials, and pre-release quarterly financial reports. Access requires two-person approval and zero-trust hardware attestation.

2. Password Standards, MFA & Endpoint Device Security

2.1 Passphrase Complexity: Passphrases must be a minimum of sixteen (16) characters in length, containing uppercase letters, lowercase letters, numbers, and symbols. Automated rotation is enforced every 90 days.

2.2 Multi-Factor Authentication (MFA): MFA is mandatory across all cloud applications, VPN endpoints, and email suites. Hardware FIDO2 security keys (YubiKeys) or certified authenticator apps (Google/Microsoft Authenticator) are required. SMS-based 2FA is strictly banned due to vulnerability to SIM-swap attacks.

2.3 Screen Inactivity Lock: All workstations and laptops must automatically lock after five (5) minutes of user inactivity.

2.4 Full-Disk Encryption: BitLocker (Windows) and FileVault (macOS) full-disk encryption with 256-bit keys is mandatory. Removable USB flash drives and external storage devices are blocked by endpoint management software.

3. Incident Response Protocol & Data Breach SLAs

3.1 SLA for Incident Reporting: Any team member who discovers or suspects a security breach, lost corporate laptop, ransomware infection, or unauthorized data access must notify the Security Operations Center (SOC) within sixty (60) minutes of discovery at incident-response@acmeglobal.com.

3.2 Containment SLA: The SOC must acknowledge P1 critical breaches within 15 minutes and achieve network isolation/containment within four (4) hours.

3.3 Proprietary Information: Under the signed Proprietary Information and Inventions Agreement (PIIA), all code, models, and technical architecture authored during employment remain exclusive corporate property.

4. Artificial Intelligence (AI) & LLM Acceptable Use Policy

4.1 Public AI Tools Prohibition: Entering Tier 3 (Confidential) or Tier 4 (Highly Restricted) corporate data, customer data, or internal source code into public, consumer AI tools (e.g., standard ChatGPT, Claude, Gemini) is strictly forbidden.

4.2 Approved Enterprise AI: Employees may only use corporate-contracted enterprise AI accounts where data privacy agreements guarantee zero data retention and zero training on Acme inputs.

4.3 AI Code Assistants: AI code completion tools (e.g., GitHub Copilot Enterprise) are permitted only on approved repositories and all AI-generated code must undergo mandatory automated Static Application Security Testing (SAST) and peer review before merging.

5. Remote Access, VPN & Wi-Fi Security Protocols

5.1 Public Wi-Fi Warning: When working from coffee shops, hotels, or airports, connecting via the Acme Corporate WireGuard VPN is mandatory prior to opening any business application.

5.2 Split Tunneling Prohibited: Split tunneling on corporate VPN connections is permanently disabled to ensure all network traffic passes through cloud threat inspection and intrusion detection filters.

5.3 Mobile Device Management (MDM): Personal mobile devices accessing corporate email or Slack must enroll in Acme MDM. Rooted or jailbroken mobile devices are blocked by automated compliance policies.

6. Cloud Infrastructure, Secrets & Key Management

6.1 Zero-Trust IAM: Access to AWS, Google Cloud, and Azure environments is governed by Least Privilege Role-Based Access Control (RBAC). Permanent administrative credentials are prohibited; just-in-time (JIT) elevated access expires after four (4) hours.

6.2 Secret Key Rotation: Production API keys, database credentials, and service account tokens must be rotated every 90 days.

6.3 Hardcoded Secrets Ban: Storing plaintext passwords or API keys in Git source repositories is a critical security violation. All repositories enforce automated pre-commit secret scanning hooks (GitLeaks) that block commits containing credentials.